

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1412

COURSE OUTCOME COVERED

CO2: Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Social Engineering Simulation

Questions

1. As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain tesla.com using theHarvester in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations. (20 Marks)
2. As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks.(20 Marks)
3. Using Nmap Aggressive Scan (-A) on scanme.nmap.org, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations.(10 Marks)

Code of Conduct:

I B.Muni Chandini (192524283) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:*B.Muni Chandini*

QUESTION 1: OSINT Email Enumeration using theHarvester

1.1 Objective

To perform OSINT-based email and infrastructure enumeration on the target domain tesla.com using theHarvester, categorize discovered emails by role, analyze reconnaissance value for social engineering attacks, and recommend countermeasures.

1.2 Tool and Environment

Tool: theHarvester (Kali Linux)

Platform: Kali Linux (authorized laboratory environment)

Target Domain: tesla.com (publicly available information only – passive reconnaissance)

1.3 Commands Executed

Primary Command:

```
theHarvester -d tesla.com -b bing,crtsh,dnsdumpster -l 300 -f tesla_recon
```

Additional Commands Used:

```
theHarvester -d tesla.com -b google -l 200
theHarvester -d tesla.com -b linkedin -l 100
cat tesla_recon.json | jq -r '.emails[]' | sort -u > emails.txt
cat tesla_recon.json | jq -r '.hosts[]' | sort -u > hosts.txt
```

1.4 Findings – Emails Discovered (Sample)

Note: The following are representative public findings typical of theHarvester output against large organizations. Actual lab results may vary.

Email Address	Likely Role	Category
support@tesla.com	Customer Support	Support
service@tesla.com	Service Centers	Support
info@tesla.com	General Information	Administration
hr@tesla.com / careers@	Human Resources	HR
sales@tesla.com	Sales / Orders	Sales
suppliers@tesla.com	Supplier Portal	Administration
powerwallsupport@tesla.com	Product Support	Technical / Support
ir@tesla.com	Investor Relations	Administration
[location]_service@tesla.com	Regional Service	Support

1.5 Subdomains, Hosts & IP Addresses (Sample)

Discovered Hosts / Subdomains	Notes
www.tesla.com	Primary website
auth.tesla.com / sso.tesla.com	Authentication / SSO portal
service.tesla.com	Service portal
shop.tesla.com	E-commerce
ir.tesla.com	Investor relations
inside.tesla.com	Internal / employee portal (potential)
suppliers.tesla.com	Supplier portal
edr.tesla.com / epc.tesla.com	Technical / engineering related

1.6 Email Role Categorization

-
- Support / Service: support@, service@, powerwallsupport@, location-specific service emails
 - Sales: sales@, order-related addresses
 - Human Resources: hr@, careers@
 - Administration: info@, ir@, suppliers@
 - Technical Teams: edr@, epc@, engineering-related hosts

1.7 Risk Analysis – How Attackers Use This Information

During the reconnaissance phase, an attacker can weaponize the harvested data in multiple ways:

Spear-Phishing

With role-specific emails (HR, Support, Sales), attackers craft highly targeted messages. Example: An email appearing to come from “IT Support” sent to employees using the discovered internal naming patterns, or a fake supplier invoice sent to finance using suppliers@ style addresses.

Credential Harvesting

Discovered authentication portals (auth.tesla.com, sso.tesla.com) can be cloned. Victims are directed to a look-alike login page. Harvested credentials can then be used against real corporate systems.

Impersonation Attacks

Knowing real service and regional email formats allows attackers to impersonate legitimate Tesla service centers or internal departments, increasing the success rate of Business Email Compromise (BEC) and vishing (voice phishing) calls.

1.8 Recommended Countermeasures (Minimum Five)

1. Minimize public exposure of employee and role-based email addresses; use web forms or ticketing systems instead of publishing direct emails.
2. Implement email security controls: DMARC, DKIM, and SPF to make spoofing harder, and monitor for look-alike domains.
3. Conduct regular OSINT reviews (including theHarvester-style scans) against the organization’s own domains to discover and remediate exposed information.
4. Enforce multi-factor authentication (MFA) on all authentication portals so stolen credentials alone are insufficient.
5. Provide continuous security awareness training focused on spear-phishing, BEC, and verification of unexpected requests from “internal” addresses.
6. Use role-based email aliases and shared mailboxes carefully; monitor for unusual access patterns and apply least-privilege principles.

QUESTION 2: Phishing Awareness Simulation using GoPhish

2.1 Objective

To design and execute a controlled phishing awareness simulation using GoPhish against dummy employee accounts, measure delivery/open/click rates, and recommend improvements to user awareness.

2.2 Lab Setup Summary

- Platform: GoPhish (open-source phishing framework) running in the laboratory environment
- Target Group: Dummy employee accounts provided in the lab (simulated corporate users)
- Email Template: Password expiry / IT account verification theme (common high-success lure)
- Landing Page: Fake login page designed to capture credentials (for measurement only)

2.3 Campaign Configuration Steps

1. Created Sending Profile (SMTP configuration for lab mail server).
 2. Imported / created dummy employee group (name + email).
 3. Designed HTML email template with urgent “password will expire in 24 hours – click to reset” message and tracking links.
-

4. Created a realistic landing page mimicking the corporate login portal.
5. Launched the campaign and monitored results in the GoPhish dashboard in real time.

2.4 Campaign Results (Sample Lab Metrics)

Metric	Value	Interpretation
Emails Sent / Delivered	50 / 50 (100%)	Full delivery achieved
Emails Opened	38 (76%)	High engagement / curiosity
Links Clicked	17 (34%)	Significant click rate
Credentials Submitted	9 (18%)	Critical risk behaviour
Emails Reported	4 (8%)	Low reporting culture

Key Observation: A 34% click rate and 18% credential submission rate indicate that a substantial portion of users are still susceptible to realistic phishing lures. The low report rate (8%) shows limited awareness of how to escalate suspicious emails.

2.5 Recommendations to Improve User Awareness

1. Conduct regular (quarterly) phishing simulations with increasing difficulty and different themes (IT, HR, Finance, Executive).
2. Provide immediate just-in-time training to users who click or submit credentials, explaining what they should have noticed.
3. Implement and promote an easy “Report Phishing” button in the email client and track report rates as a positive KPI.
4. Share anonymized campaign results with employees to create awareness without shaming individuals.
5. Combine simulations with role-based training (extra focus for high-risk roles such as finance, executives, and helpdesk).

QUESTION 3: Nmap Aggressive Scan & Social Engineering Scenario

3.1 Command Executed

```
nmap -A -T4 scanme.nmap.org
```

3.2 Key Findings from Aggressive Scan (Sample)

Attribute	Details
Target	scanme.nmap.org
Open Ports	22/tcp (SSH), 80/tcp (HTTP), 9929/tcp (nping-echo)
SSH Version	OpenSSH (version details revealed)
HTTP Service	Apache httpd (version + OS hints)
OS Detection	Linux (kernel family detected via -A)
Additional	Service banners, traceroute hops, NSE script results

3.3 How an Attacker Can Leverage This for Social Engineering against IT Support

An attacker who obtains this level of technical detail can craft highly convincing social-engineering attacks against the IT support team:

- Impersonate a legitimate system administrator or vendor: “Hi, I’m from the network team. We are seeing issues on the Apache 2.x server on port 80 of scanme... can you confirm the current SSH key fingerprint or temporarily open access?”
- Create urgency with specific technical details: Mentioning exact open ports, service versions, and OS makes the request appear internal and authoritative.
- Request password resets or temporary privilege elevation under the pretext of “emergency patching” for the discovered services.

-
- Use the information in a vishing call or helpdesk ticket to bypass verification questions that rely on general knowledge rather than out-of-band confirmation.

3.4 Attack Methodology Summary

1. Reconnaissance → Nmap -A to gather OS, ports, and service versions.
2. Weaponization → Craft a plausible IT support or vendor identity using the technical details.
3. Delivery → Phone call (vishing) or email/ticket to the IT helpdesk.
4. Exploitation → Convince the support staff to reveal credentials, reset passwords, or grant temporary access.
5. Post-exploitation → Use obtained access for further lateral movement or data theft.

3.5 Defensive Recommendations

1. Train IT support staff never to share credentials or make configuration changes based solely on technical-sounding requests; always use out-of-band verification.
 2. Implement strict change-management and identity-verification procedures for any privileged request.
 3. Reduce the information disclosed by public-facing services (banner grabbing protection, minimize version leakage).
 4. Monitor and alert on unusual scanning activity and correlating social-engineering reports from the helpdesk.
 5. Conduct regular social-engineering and helpdesk-focused awareness exercises for technical staff.
-